데스크톱 앱 (Tauri, Windows)

Tauri 2.12 셸이 Next.js standalone 서버를 내장 Node 런타임(v24.13.0)으로 실행하고, 메인 창이 http://127.0.0.1:34110을 연다. 웹 앱 전체 기능을 PC에서 쓰는 것이 목적이다. 개발용 무서명 NSIS 설치 파일만 만든다 (macOS·서명·자동 업데이트는 후속).

빌드

powershell -ExecutionPolicy Bypass -File scripts/desktop-build.ps1 # -SkipWebBuild 로 웹 빌드 생략

순서: apps/web build → standalone·.next/static·public·Node 런타임(공식 zip, SHA256 검증)·Node LICENSE를 apps/desktop/src-tauri/resources/에 복사 → tauri build --bundles nsis → 설치 크기 출력.

필요: Rust stable(MSVC), Node 24, WebView2. 결과: apps/desktop/src-tauri/target/release/bundle/nsis/Content Flow AI_<버전>_x64-setup.exe. 첫 빌드는 NSIS를 내려받는다(실패하면 재실행).

측정(2026-11-12): 설치 파일 25.3 MB, 풀린 resources 110 MB(상한 200 MB).

설치·데이터 위치

- 사용자 단위 설치(관리자 권한 불필요).

- identifier(com.contentflow.desktop)와 포트 34110은 바꾸지 않는다. 로컬 모드 데이터(WebView 저장소)가 출처(127.0.0.1:34110)와 identifier 폴더에 묶여 있어, 바꾸면 기존 글이 보이지 않게 된다. 업데이트·재설치는 사용자 데이터 폴더를 지우지 않는다.

- 포트가 사용 중이면 다른 포트로 바꾸지 않고 오류 화면을 보여준다.

키·설정 (%APPDATA%₩ContentFlow₩desktop.env)

KEY=VALUE 줄. 허용 목록만 서버로 전달된다: SUPABASE_URL, SUPABASE_PUBLISHABLE_KEY, APP_URL, COOKIE_SECURE, GEMINI_API_KEY, OPENAI_API_KEY, WP_*. 그 밖의 값(NODE_OPTIONS 등)은 무시한다. service role 키는 넣지 않는다.

키 파일은 평문이며 Windows 사용자 계정 권한으로만 보호된다. 파일이 없으면 로컬 모드로 동작한다.

보안 구조

- 서버는 127.0.0.1에만 바인딩. 실행마다 난수 토큰(64 hex)을 만들어 서버 env(DESKTOP_TOKEN)로 준다. 서버는 정확한 Host와 cf_desktop 쿠키가 없으면 403.

- 준비 확인은 TCP가 아니라 /api/health?nonce=의 HMAC 일치로만 통과. 이후 /desktop-auth?t=로 쿠키를 받는다.

- 메인 창(원격 출처)에는 IPC capability가 없다. 시작·오류 화면만 번들 페이지이고 retry·quit_app 두 명령만 허용한다.

- 외부 링크·새 창(http/https/mailto)은 시스템 브라우저로 열고 앱 창은 이동하지 않는다.

- 서버 프로세스는 Windows Job Object(KILL_ON_JOB_CLOSE)에 넣어 앱이 강제 종료돼도 함께 종료된다. %LOCALAPPDATA%₩ContentFlow₩sidecar.pid는 우리 node.exe 경로일 때만 다음 시작에 정리한다.

- 단일 인스턴스: 두 번째 실행은 서버를 띄우지 않고 기존 창을 앞으로 가져온다.

- 서버 stdout·stderr는 저장하지 않는다(인증 URL·env 유출 방지).

- 원격 출처(127.0.0.1) 페이지에서 invoke는 ACL(capability에 원격 URL 없음)로 거부된다. withGlobalTauri는 꺼 두었지만 내부 브리지는 모든 페이지에 주입되므로 방어선은 ACL이다.

- 위협 메모: 설치 파일은 무서명이고 사용자 단위(currentUser) 설치라 사용자 쓰기 가능 폴더의 DLL 심기·파일 교체 위험이 있다. 서명·SmartScreen 대응은 후속.

- Job Object 생성·할당에 실패하면 서버를 종료하고 오류 화면(job_failed)을 보여준다(고아 프로세스 방지).

- 재시작 경합: 시작 시도는 Mutex로 직렬화하고 세대 번호로 낡은 시도의 자식 프로세스·pid 정리를 막는다.

- Node zip SHA256은 desktop-build.ps1에 고정되어 있고 매 빌드마다 검증·재추출한다(버전을 올리면 해시도 함께 갱신).

- 메인 창 CSP는 Next 응답 헤더 몫이며 이 문서 범위 밖이다.

알려진 제한 (W0)

- 계정 모드의 메일 링크(재설정·확인)는 시스템 브라우저로 열려 세션이 앱으로 오지 않는다.

- 계정 모드 로그인 후 앱 재시작 시 세션 유지는 미실측.

- 서명·SmartScreen 경고, 자동 업데이트, macOS 빌드 없음.

- 서버가 죽으면 오류 화면으로 이동하고 자동 재시도하지 않는다(다시 시도 버튼).